

Normas da família ISO 27000



UNIVERSIDADE
FEDERAL DO CEARÁ
CAMPUS QUIXADÁ

Roberto Cabral

Universidade Federal do Ceará

July 11, 2025



Revisão

- Ameaças - Causa potencial (agente) de um incidente indesejado, que pode resultar em dano para um sistema ou organização [ISO 27002].
 - Podem colocar em risco a confidencialidade, integridade e disponibilidade das informações.
 - São classificadas em: Naturais (natureza), Intencionais (maldades) e Involuntárias (despreparo e desconhecimento humano).
- Vulnerabilidades - Fragilidade de um ativo ou grupo de ativos que pode ser explorada por uma ou mais ameaças [ISO 27002].
- Riscos: é a Probabilidade de uma AMEAÇA explorar uma VULNERABILIDADES.
 - Causando perdas ou danos aos ativos e consequente impacto no negócio.



Revisão

- **Sistema de Gestão da Segurança da Informação (SGSI)** - a parte do sistema de gestão global, baseado na abordagem de riscos do negócio, para estabelecer, implementar, operar, monitorar, analisar criticamente, manter e melhorar (EIOMAMM) a segurança da informação. Inclui: estrutura organizacional, políticas, planejamento de atividades, responsabilidades, práticas, procedimentos, processos e recursos.
- **Evento de segurança da informação** - uma ocorrência identificada de um estado de sistema, serviço ou rede indicando uma possível violação da política de segurança da informação ou falha de controles, ou uma situação previamente desconhecida, que possa ser relevante para a segurança da informação.



Revisão

- **Incidente de segurança da informação** - um simples ou uma série de eventos de segurança da informação indesejados ou inesperados, que tenham uma grande probabilidade de comprometer as operações do negócio e ameaçar a segurança da informação. Pode-se simplificarmente afirmar que é um conjunto de eventos e é crítico, enquanto o evento de segurança da informação é apenas relevante.
- **Declaração de aplicabilidade** - declaração documentada que descreve os objetivos de controle e controles que são pertinentes e aplicáveis ao SGSI da organização.

Revisão

- **Confidencialidade** - propriedade de que a informação não esteja disponível ou revelada a indivíduos, entidades ou processos não autorizados.
- **Integridade** - propriedade de salvaguarda da exatidão e completeza de ativos.
- **Ativo** - qualquer coisa que tenha valor para a organização.

Introdução

- Apresentação a evolução e o objetivo de cada uma das principais normas que fazem parte da ISO 27000;
- Explicar os objetivos de controle do Código de Prática para Gestão da Segurança da Informação;
- Descrever a relação entre normas, leis e recomendações.

Introdução

- O que são e para que servem as normas?
 - É aquilo que se estabelece como medida para a realização de uma atividade.
 - Uma norma tem como propósito definir regras e instrumentos de controle para assegurar a conformidade de um processo, produto ou serviço.

Introdução

- Conforme definido pela Associação Brasileira de Normas Técnicas (ABNT), os objetivos da normalização são:
 - Comunicação - proporcionar meios mais eficientes na troca de informação entre o fabricante e o cliente, melhorando a confiabilidade das relações comerciais e de serviços;
 - Segurança - proteger a vida humana e a saúde;
 - Proteção do consumidor - prover a sociedade de mecanismos eficazes para aferir qualidade de produtos;
 - Eliminação de barreiras técnicas e comerciais - evitar a existência de regulamentos conflitantes sobre produtos e serviços em diferentes países, facilitando assim, o intercâmbio comercial.

A família ISO/IEC 27000 - Sistemas de Gestão da Segurança da Informação

- **ISO/IEC 27000:2018 - Sistemas de Gestão da Segurança da Informação - Visão Geral e Vocabulário**

- **Explicação:** Esta norma introduz a família ISO/IEC 27000, fornecendo uma visão geral dos conceitos de sistemas de gestão da segurança da informação (SGSI) e definindo os termos e vocabulários utilizados em toda a série de normas. É o ponto de partida para entender o universo da ISO 27000.
- **Exemplo:** Uma equipe de auditoria de SI consultaria a ISO/IEC 27000 para garantir que todos os membros utilizem a mesma terminologia (ex: "ativo", "risco", "vulnerabilidade", "ameaça") ao discutir a segurança da informação com a organização auditada, evitando mal-entendidos.



A família ISO/IEC 27000 - Sistemas de Gestão da Segurança da Informação

- **ISO/IEC 27001:2022 - Sistemas de Gestão da Segurança da Informação - Requisitos**
 - **Explicação:** Esta é a norma central da família. Ela especifica os requisitos para estabelecer, implementar, manter e melhorar continuamente um Sistema de Gestão da Segurança da Informação (SGSI) dentro do contexto da organização. É a norma contra a qual as empresas podem ser certificadas.
 - **Exemplo:** Um auditor de SI, ao avaliar a segurança de uma empresa de e-commerce, verificaria se a empresa possui um SGSI documentado que atende às cláusulas mandatórias da ISO 27001:2022, como a identificação de riscos de segurança (Cláusula 6) e o comprometimento da liderança (Cláusula 5).



A família ISO/IEC 27000 - Sistemas de Gestão da Segurança da Informação

- **ISO/IEC 27002:2022 - Segurança da Informação, Segurança Cibernética e Proteção da Privacidade - Controles de Segurança da Informação**
 - **Explicação:** Esta norma fornece um código de prática com diretrizes detalhadas para a implementação dos controles de segurança da informação mencionados no Anexo A da ISO 27001. Não é uma norma de certificação para empresas, mas um guia prático para implementar os “como fazer”.
 - **Exemplo:** Após identificar que a empresa precisa de um controle de acesso eficaz (requisito da ISO 27001), o auditor consultaria a ISO 27002:2022 (Controle 8.5 - Gerenciamento de acesso privilegiado) para entender as melhores práticas sobre como implementar e gerenciar o acesso de usuários com altos privilégios.



A família ISO/IEC 27000 - Sistemas de Gestão da Segurança da Informação

- **ISO/IEC 27003:2017 - Tecnologia da Informação - Técnicas de Segurança - Diretrizes para a Implementação de um Sistema de Gestão da Segurança da Informação**
 - **Explicação:** Esta norma oferece diretrizes práticas e detalhadas para o processo de implementação de um SGSI, conforme os requisitos da ISO/IEC 27001. Ela serve como um roteiro para as organizações que estão construindo seu sistema de gestão.
 - **Exemplo:** Um auditor de SI, ao revisar o projeto de implementação de um SGSI em uma nova empresa, verificaria se o plano de projeto segue as fases e recomendações da ISO/IEC 27003 para garantir uma implementação estruturada e eficaz.



A família ISO/IEC 27000 - Sistemas de Gestão da Segurança da Informação

- **ISO/IEC 27004:2016 - Tecnologia da Informação - Técnicas de Segurança - Monitoramento, Medição, Análise e Avaliação da Segurança da Informação**
 - **Explicação:** Esta norma fornece diretrizes para como medir a eficácia de um SGSI e dos controles de segurança da informação. Ela ajuda as organizações a estabelecer métricas e indicadores para monitorar o desempenho da segurança.
 - **Exemplo:** Um auditor de SI, ao avaliar o desempenho do SGSI de uma empresa, solicitaria relatórios de métricas baseados na ISO/IEC 27004, como o número de incidentes de segurança resolvidos dentro do SLA ou a porcentagem de funcionários que completaram o treinamento de conscientização de segurança.

A família ISO/IEC 27000 - Sistemas de Gestão da Segurança da Informação

- **ISO/IEC 27005:2022 - Segurança da Informação, Segurança Cibernética e Proteção da Privacidade - Diretrizes para Gestão de Riscos de Segurança da Informação**
 - **Explicação:** Esta norma fornece diretrizes para a gestão de riscos de segurança da informação, suportando a Cláusula 6 da ISO 27001. Ela detalha as etapas de identificação, análise, avaliação, tratamento e comunicação de riscos.
 - **Exemplo:** Um auditor de SI, ao avaliar o processo de gestão de riscos de uma empresa, verificaria se a metodologia utilizada para identificar e avaliar riscos de segurança (ex: risco de vazamento de dados de clientes) segue as diretrizes da ISO/IEC 27005.



A família ISO/IEC 27000 - Sistemas de Gestão da Segurança da Informação

- **ISO/IEC 27007:2020 - Diretrizes para Auditoria de Sistemas de Gestão da Segurança da Informação**
 - **Explicação:** Esta norma fornece diretrizes sobre como gerenciar um programa de auditoria de SGSI e como executar auditorias (internas ou externas) e a competência de auditores de SGSI, complementando a ISO 19011 (diretrizes gerais para auditoria de sistemas de gestão).
 - **Exemplo:** Um auditor de SI, ao planejar uma auditoria interna do SGSI de sua própria organização, consultaria a ISO/IEC 27007 para garantir que o programa de auditoria seja bem estruturado, que os auditores sejam competentes e que o processo de auditoria seja eficaz.



A família ISO/IEC 27000 - Sistemas de Gestão da Segurança da Informação

- **ISO/IEC 27011:2016 - Tecnologia da Informação - Técnicas de Segurança - Diretrizes para Gestão da Segurança da Informação para Organizações de Telecomunicações baseadas na ISO/IEC 27002**
 - **Explicação:** Esta norma oferece diretrizes específicas para a implementação da gestão de segurança da informação em organizações do setor de telecomunicações, baseando-se nos controles da ISO/IEC 27002.
 - **Exemplo:** Um auditor de SI, ao auditar uma operadora de telefonia, utilizaria a ISO/IEC 27011 para verificar se os controles de segurança específicos para redes de telecomunicações (ex: proteção de infraestrutura de rede, segurança de dados de tráfego) estão adequadamente implementados.



A família ISO/IEC 27000 - Sistemas de Gestão da Segurança da Informação

- **ISO/IEC 27014:2020 - Tecnologia da Informação - Técnicas de Segurança - Governança de Segurança da Informação**
 - **Explicação:** Esta norma fornece orientação sobre conceitos e princípios para a governança de segurança da informação. Ela ajuda as organizações a avaliar, direcionar, monitorar e comunicar as atividades relacionadas com a segurança da informação em nível estratégico.
 - **Exemplo:** Um auditor de SI, ao avaliar a governança de segurança da informação de uma grande corporação, verificaria se a alta direção está ativamente envolvida na definição da estratégia de segurança e no monitoramento do desempenho, conforme as diretrizes da ISO/IEC 27014.



A família ISO/IEC 27000 - Sistemas de Gestão da Segurança da Informação

- **ISO/IEC 27031:2011 - Tecnologia da Informação - Técnicas de Segurança - Diretrizes para a Prontidão para a Continuidade dos Negócios da Tecnologia da Informação e Comunicação**
 - **Explicação:** Descreve os conceitos e princípios da prontidão esperada para a tecnologia de comunicação e informação (TIC) na continuidade dos negócios. Fornece uma estrutura para identificar e especificar aspectos para garantir a continuidade dos serviços de TIC em caso de incidentes.
 - **Exemplo:** Um auditor de SI, ao avaliar o plano de continuidade de negócios de uma empresa, utilizaria a ISO/IEC 27031 para verificar se os recursos de TIC (sistemas, redes, dados) estão prontos para suportar as operações críticas durante e após um desastre.



A família ISO/IEC 27000 - Sistemas de Gestão da Segurança da Informação

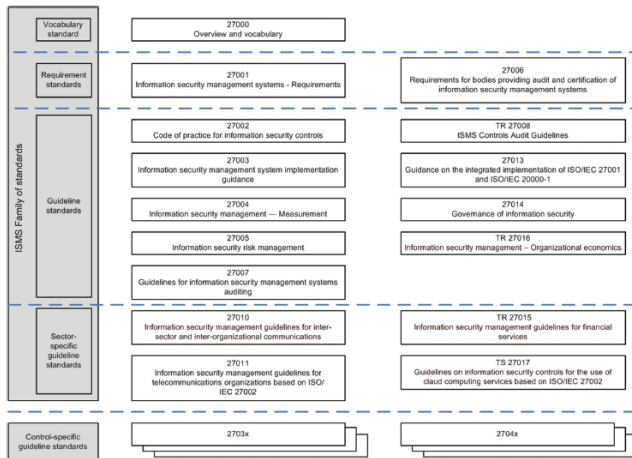
- **ISO/IEC 27032:2023 - Segurança Cibernética - Diretrizes para Segurança Cibernética**
 - **Explicação:** Fornece diretrizes para melhorar o estado de Segurança Cibernética, traçando os aspectos típicos desta atividade e suas ramificações em outros domínios de segurança, como segurança de rede e segurança de aplicações.
 - **Exemplo:** Um auditor de SI, ao avaliar a postura de cibersegurança de uma empresa, consultaria a ISO/IEC 27032 para verificar se a organização possui estratégias e controles eficazes para se proteger contra ameaças cibernéticas comuns, como ataques de ransomware e phishing.

A família ISO/IEC 27000 - Sistemas de Gestão da Segurança da Informação

- **ISO/IEC 27037:2012 - Tecnologia da Informação - Técnicas de Segurança - Diretrizes para Identificação, Coleta, Aquisição e Preservação de Evidência Digital**
 - **Explicação:** Fornece diretrizes para atividades específicas no manuseio de evidências digitais (como dados de computadores, celulares, redes) que possam possuir valor probatório em investigações ou processos legais.
 - **Exemplo:** Um auditor de SI, ao investigar um incidente de segurança que pode levar a uma ação legal, utilizaria a ISO/IEC 27037 para garantir que a identificação, coleta e preservação de logs de sistema ou imagens de disco sejam feitas de forma forense sólida, mantendo a cadeia de custódia da evidência.



A família 27000



Norma ISO/IEC 27001:2022 - Estrutura Geral

- Introdução
- Escopo
- Referências Normativas
- Termos e Definições
- Cláusula 4: Contexto da Organização
- Cláusula 5: Liderança
- Cláusula 6: Planejamento
- Cláusula 7: Apoio
- Cláusula 8: Operação
- Cláusula 9: Avaliação de Desempenho
- Cláusula 10: Melhoria

● **Anexo A** - Referência aos controles de segurança da ISO/IEC 27002:2022

Norma ISO/IEC 27001:2022 - Introdução

- Esta Norma foi preparada para prover requisitos para estabelecer, implementar, manter e melhorar continuamente (EIMM) um Sistema de Gestão da Segurança da Informação (SGSI).
- O estabelecimento e a implementação do SGSI de uma organização são influenciados por suas necessidades e objetivos, requisitos de segurança, processos organizacionais usados, tamanho e estrutura da organização.
- É esperado que todos estes fatores de influência mudem ao longo do tempo, tornando o SGSI um processo dinâmico e de melhoria contínua.
- **Para o Auditor:** O auditor verifica se o SGSI é um sistema vivo, que se adapta e evolui com a organização.



Compatibilidade da ISO/IEC 27001:2022 (Estrutura de Alto Nível - HLS)

- A ISO/IEC 27001:2022 segue a **Estrutura de Alto Nível (HLS)** comum a todas as normas de sistemas de gestão da ISO.
- Isso **facilita a integração** de múltiplos sistemas de gestão dentro de uma organização, como:
 - Sistema de Gestão da Qualidade (ISO 9001)
 - Sistema de Gestão Ambiental (ISO 14001)
 - SGSI (ISO 27001)
- O processo é facilitado, visto que essas normas possuem uma estrutura idêntica nas cláusulas mandatórias (4 a 10), simplificando o entendimento e a aplicação.



Norma ISO/IEC 27001:2022 - Escopo e Requisitos Mandatórios

- A norma especifica os requisitos para estabelecer, implementar, manter e melhorar continuamente um SGSI dentro do contexto da organização.
- Inclui requisitos para a avaliação e tratamento de riscos de segurança da informação.
- Os requisitos definidos nesta norma são genéricos e são pretendidos para serem aplicáveis a todas as organizações, independentemente do tipo, tamanho ou natureza.

Norma ISO/IEC 27001:2022 - Escopo e Requisitos Mandatórios

- **Requisitos Mandatórios:** As Seções **4 a 10** da norma contêm os requisitos obrigatórios. A exclusão de quaisquer destes requisitos **não é aceitável** quando a organização busca a conformidade ou certificação com esta Norma.
- **Para o Auditor:** O auditor deve verificar o cumprimento de **TODOS** os requisitos das cláusulas 4 a 10 para atestar a conformidade do SGSI.
- **Exemplo:** Para a TechVendas Online, o escopo do SGSI pode ser definido como “a proteção dos dados de clientes e vendas na plataforma de e-commerce e no sistema ERP”. O auditor verificaria se todos os requisitos da ISO 27001 são aplicados a este escopo, sem exceções nas cláusulas mandatórias.



Cláusula 4: Contexto da Organização

- **4.1 Compreendendo a Organização e seu Contexto:**

- A organização deve determinar as questões internas e externas que são relevantes para o seu propósito e que afetam sua capacidade para alcançar os resultados pretendidos do seu SGSI.
- **Exemplo:** A TechVendas Online deve analisar questões externas (ex: novas ameaças cibernéticas, regulamentações como LGPD) e internas (ex: rápido crescimento, dependência de sistemas de TI, cultura organizacional) que impactam sua segurança da informação. O auditor verificaria se essas questões foram identificadas e documentadas.

Cláusula 4: Contexto da Organização

- **4.2 Compreendendo as Necessidades e Expectativas das Partes Interessadas:**
 - A organização deve determinar as partes interessadas relevantes para o SGSI e os requisitos dessas partes interessadas para a segurança da informação.
 - **Exemplo:** Para a TechVendas Online, as partes interessadas incluem clientes (que esperam privacidade de dados), reguladores (LGPD), fornecedores de nuvem (segurança da infraestrutura), e funcionários (acesso seguro aos sistemas). O auditor verificaria como a empresa identifica e atende a essas expectativas, por exemplo, através de contratos ou políticas internas.

Cláusula 4: Escopo do SGSI e Informação Documentada

● 4.3 Determinando o Escopo do Sistema de Gestão da Segurança da Informação:

- A organização deve determinar os limites e a aplicabilidade do SGSI para estabelecer o seu escopo.
- Sobre este escopo, a organização deve considerar: as questões internas e externas (4.1), os requisitos das partes interessadas (4.2), e as interfaces e dependências entre as atividades desempenhadas pela organização e por outras (ex: provedores de nuvem).
- **Exemplo:** O escopo do SGSI da TechVendas Online pode ser "a proteção dos dados de clientes e vendas na plataforma de e-commerce e no sistema ERP, incluindo a infraestrutura de rede e os processos de desenvolvimento e operações de TI". O auditor verificaria se este escopo está claramente definido e documentado.



Cláusula 4: Escopo do SGSI e Informação Documentada

- **Informação Documentada como Evidência de Auditoria:**
 - Sempre que a norma cita que algo deve estar **disponível como informação documentada**, isso significa que se trata de **evidência de auditoria** de que o(s) requisito(s) da norma está(ão) sendo cumprido(s).
 - **Exemplo:** O auditor da TechVendas Online exigiria o documento formal do "Escopo do SGSI" como evidência de que a Cláusula 4.3 foi atendida.

Cláusula 5: Liderança - Comprometimento da Alta Direção

- A Alta Direção deve demonstrar sua liderança e comprometimento em relação ao SGSI pelos seguintes meios:
 - Assegurando que a política de segurança da informação e os objetivos de segurança da informação estão estabelecidos e são compatíveis com a direção estratégica da organização.
 - Garantindo a integração dos requisitos do SGSI dentro dos processos da organização.
 - Assegurando que os recursos necessários para o SGSI estão disponíveis.
 - Comunicando a importância de uma gestão eficaz da segurança da informação e da conformidade com os requisitos do SGSI.
 - Assegurando que o SGSI alcança seus resultados pretendidos.
 - Orientando e apoiando pessoas que contribuam para a eficácia do SGSI.
 - Promovendo a melhoria contínua.



Cláusula 5: Liderança - Comprometimento da Alta Direção

- **Para o Auditor:** O auditor procuraria evidências de que a Alta Direção não apenas “diz” que se importa com a segurança, mas age de forma proativa.
- **Exemplo:** Um auditor de SI, ao verificar a liderança na TechVendas Online, procuraria atas de reuniões do conselho onde investimentos em segurança foram aprovados, e-mails do CEO comunicando a importância da segurança, ou a participação ativa do Diretor de TI em comitês de segurança.



Cláusula 5: Política e Papéis Organizacionais

● 5.2 Política de Segurança da Informação:

- A Alta Direção deve estabelecer uma política de segurança da informação que seja apropriada ao propósito da organização, inclua objetivos de segurança, compromisso com requisitos aplicáveis e melhoria contínua.
- A política deve estar disponível como informação documentada, ser comunicada dentro da organização e estar disponível para as partes interessadas, conforme apropriado.
- **Exemplo:** A política de segurança da informação da TechVendas Online deve ser mais do que um documento em uma gaveta. O auditor verificaria se ela está publicada na intranet, se os funcionários foram treinados sobre ela, e se é revisada anualmente para refletir novas ameaças ou mudanças no negócio.

Cláusula 5: Política e Papéis Organizacionais

- **5.3 Papéis, Responsabilidades e Autoridades Organizacionais:**

- A Alta Direção deve assegurar que as responsabilidades e autoridades dos papéis relevantes para a segurança da informação sejam atribuídos e comunicados.
- **Exemplo:** O auditor verificaria se a TechVendas Online tem um "Encarregado de Dados (DPO)" ou um "Chief Information Security Officer (CISO)" com responsabilidades e autoridades claras para o SGSI (ex: gerenciar incidentes, garantir conformidade com a LGPD), e se essa estrutura é conhecida por todos os departamentos.

Cláusula 6: Planejamento - Ações para Riscos e Oportunidades

- A organização deve planejar ações para considerar riscos e oportunidades, e como:
 - Integrar e implementar estas ações dentro dos processos do seu SGSI; e
 - Avaliar a eficácia destas ações.

Cláusula 6: Planejamento - Ações para Riscos e Oportunidades

- **6.1.2 Avaliação de Riscos de Segurança da Informação:**
 - A organização deve definir e aplicar um processo de avaliação de riscos de segurança da informação que estabeleça critérios de risco (aceitação e avaliação).
 - Deve identificar, analisar e avaliar os riscos, priorizando-os para o tratamento.
 - **Referência:** A ISO/IEC 27001:2022, nesta cláusula, **faz referência à ISO/IEC 27005** como diretriz para o processo de gestão de riscos.



Cláusula 6: Planejamento - Ações para Riscos e Oportunidades

- **6.1.2 Avaliação de Riscos de Segurança da Informação:**
 - **Exemplo:** A TechVendas Online deve ter um processo claro para identificar riscos como "ataque de ransomware que criptografa o banco de dados de clientes". O auditor verificaria se a empresa define critérios de aceitação de risco (ex: "não aceitamos risco alto de perda de dados de clientes") e se prioriza o tratamento dos riscos mais críticos, como a falta de backups testados.



Cláusula 6: Planejamento - Tratamento de Riscos e Objetivos

● 6.1.3 Tratamento de Riscos de Segurança da Informação:

- A organização deve selecionar as opções de tratamento dos riscos (ex: mitigar, aceitar, transferir, evitar).
- Deve determinar os controles necessários para implementar as opções escolhidas.
- **Comparar com o Anexo A:** É fundamental comparar os controles determinados com aqueles do Anexo A (ISO/IEC 27002) e verificar se algum controle necessário foi omitido.
- Elaborar uma **Declaração de Aplicabilidade (SoA)** que contenha os controles necessários e a justificativa para inclusões ou exclusões do Anexo A.
- Preparar um plano para tratamento dos riscos e obter a aprovação dos responsáveis.



Cláusula 6: Planejamento - Tratamento de Riscos e Objetivos

- **6.1.3 Tratamento de Riscos de Segurança da Informação:**
 - **Exemplo:** Após identificar o risco de "vazamento de dados de clientes por falha na autenticação", a TechVendas Online deve escolher opções de tratamento (ex: implementar autenticação multifator). O auditor verificaria se a "Declaração de Aplicabilidade (SoA)" da empresa lista os controles escolhidos (ex: 8.5.1 - Autenticação forte da ISO 27002) e justifica a exclusão de outros (se houver).

Cláusula 6: Planejamento - Tratamento de Riscos e Objetivos

- **6.2 Objetivos de Segurança da Informação e Planejamento para Alcançá-los:**
 - A organização deve estabelecer objetivos de segurança da informação para as funções e níveis relevantes. Devem ser consistentes com a política, mensuráveis (quando aplicável), comunicados e atualizados.
 - **Exemplo:** Um objetivo de segurança da informação da TechVendas Online poderia ser: “Reduzir em 50% o número de incidentes de segurança relacionados a acesso não autorizado nos próximos 12 meses”. O auditor verificaria se esse objetivo é mensurável, se há um plano para alcançá-lo (o que será feito, quais recursos, quem é responsável, quando será concluído) e se é comunicado à equipe.



Cláusula 7: Apoio - Recursos e Competência

- **7.1 Recursos:**

- A organização deve determinar e prover recursos necessários para o estabelecimento, implementação, manutenção e melhoria contínua do SGSI.
- **Para o Auditor:** O auditor verifica se a organização tem pessoas, infraestrutura, software e orçamento adequados para manter o SGSI.

- **7.2 Competência:**

- A organização deve determinar a competência necessária das pessoas que afetam o desempenho da segurança da informação e assegurar que são competentes (educação, treinamento, experiência).

Cláusula 7: Apoio - Conscientização, Comunicação e Informação Documentada

- **7.3 Conscientização:**

- Pessoas que realizam trabalho sob o controle da organização devem estar cientes da política de segurança, suas contribuições para o SGSI e implicações da não conformidade.

- **7.4 Comunicação:**

- A organização deve determinar as comunicações internas e externas relevantes para o SGSI (o que, quando, com quem, quem, como).

- **7.5 Informação Documentada:**

- O SGSI deve incluir informação documentada requerida pela norma e pela organização para a eficácia do SGSI.
- **Controle da Informação Documentada:** Deve estar disponível, protegida (confidencialidade, integridade), identificada, versionada, armazenada e preservada.



Cláusula 8: Operação - Implementação dos Controles

● 8.1 Planejamento e Controle Operacional:

- A organização deve planejar, implementar e controlar os processos necessários para atender aos requisitos de segurança da informação e para implementar as ações determinadas em 6.1 (riscos e oportunidades).
- Deve manter informação documentada na abrangência necessária para gerar confiança de que os processos estão sendo realizados conforme planejado.
- **Exemplo:** O auditor verificaria se a TechVendas Online possui procedimentos operacionais documentados para o backup diário dos dados de vendas (planejamento e controle operacional) e se há um processo para analisar criticamente as consequências de mudanças não previstas, como uma falha inesperada no servidor de banco de dados.



Cláusula 8: Operação - Implementação dos Controles

- **8.2 Avaliação de Riscos de Segurança da Informação:**

- A organização deve realizar avaliações de riscos de segurança da informação a intervalos planejados, ou quando mudanças significativas são propostas ou ocorrem.
- **Exemplo:** O auditor verificaria se a TechVendas Online realiza avaliações de risco de segurança periodicamente (ex: anualmente) e também quando há mudanças significativas (ex: após a implementação de um novo módulo no e-commerce), e se os resultados são documentados.

Cláusula 8: Operação - Implementação dos Controles

- **8.3 Tratamento de Riscos de Segurança da Informação:**

- A organização deve implementar o plano de tratamento de riscos de segurança da informação.
- **Exemplo:** O auditor verificaria se a TechVendas Online implementou o plano de tratamento de riscos para o risco de "vazamento de dados de clientes", por exemplo, se a criptografia dos dados em repouso e em trânsito foi efetivamente aplicada e se há evidências disso.

Cláusula 9: Avaliação de Desempenho

● 9.1 Monitoramento, Medição, Análise e Avaliação:

- A organização deve avaliar o desempenho da segurança da informação e a eficácia do SGSI.
- Deve determinar o que precisa ser monitorado e medido (controles, processos), os métodos, quando e quem deve analisar e avaliar os resultados.
- **Exemplo:** A TechVendas Online deve definir como medirá a eficácia de seu SGSI. O auditor verificaria se a empresa monitora métricas como “número de incidentes de segurança por mês”, “tempo médio de resolução de incidentes” ou “porcentagem de conformidade com a política de senhas”, e se esses resultados são analisados para identificar tendências e tomar decisões.



Cláusula 9: Avaliação de Desempenho

● 9.2 Auditoria Interna:

- A organização deve conduzir auditorias internas a intervalos planejados para prover informações sobre o quanto o SGSI está em conformidade com os próprios requisitos da organização e com os requisitos desta Norma, e se está efetivamente implementado e mantido.
- **Observações Importantes:** A responsabilidade pela condução das auditorias internas é da organização. A norma não determina uma periodicidade específica, mas exige “intervalos planejados”.
- **Exemplo:** O auditor verificaria se a TechVendas Online realiza auditorias internas em seu SGSI a intervalos planejados (ex: anualmente), se os auditores internos são independentes da área auditada e se os relatórios de auditoria interna são gerados e acompanhados pela gestão.



Cláusula 9: Avaliação de Desempenho

● 9.3 Análise Crítica pela Direção:

- A Alta Direção deve analisar criticamente o SGSI da organização a intervalos planejados, para assegurar a sua contínua adequação, pertinência e eficácia.
- Os resultados devem incluir decisões relativas a oportunidades para melhoria contínua e quaisquer necessidades para mudanças do SGSI.
- **Exemplo:** O auditor verificaria se a Alta Direção da TechVendas Online realiza reuniões de análise crítica do SGSI periodicamente (ex: semestralmente), se os resultados das auditorias internas e externas são discutidos, e se são tomadas decisões sobre melhorias e recursos para a segurança da informação.

Cláusula 10: Melhoria

- **10.1 Não Conformidade e Ação Corretiva:**

- Quando uma não conformidade ocorre, a organização deve reagir a ela (controlar e corrigir), tratar as consequências, e avaliar a necessidade de ações para eliminar as causas.
- Deve implementar quaisquer ações necessárias, analisar criticamente a eficácia das ações corretivas tomadas e realizar mudanças no SGSI, quando necessário.
- As ações corretivas devem ser apropriadas aos efeitos das não conformidades encontradas.

Cláusula 10: Melhoria

- **10.1 Não Conformidade e Ação Corretiva:**

- **Exemplo:** Se a auditoria interna da TechVendas Online encontrar uma “não conformidade” (ex: “falha na aplicação de patches em servidores críticos”), a empresa deve reagir imediatamente (corrigir a falha), investigar a causa raiz (por que o patch não foi aplicado?) e implementar ações corretivas para evitar que o problema se repita (ex: automatizar o processo de patch management). O auditor verificaria se essas ações foram eficazes e se o SGSI está continuamente melhorando.

Cláusula 10: Melhoria

- **10.2 Melhoria Contínua:**

- A organização deve continuamente melhorar a pertinência, adequação e eficácia do SGSI.
- **Para o Auditor:** O auditor busca evidências de um ciclo virtuoso de melhoria contínua, onde as lições aprendidas das não conformidades e das análises de desempenho são usadas para fortalecer o SGSI.

Anexo A da ISO/IEC 27001:2022 - Referência aos Controles

- O Anexo A da ISO/IEC 27001:2022 não contém os controles detalhados, mas sim uma **referência aos controles de segurança da informação listados na ISO/IEC 27002:2022**.
- **Para o Auditor:** O auditor usa o Anexo A como um checklist para garantir que todos os controles relevantes foram considerados e, em seguida, consulta a ISO 27002 para entender a implementação esperada de cada controle.